

GRC 101 – Week 2 Assignment

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Introduction to GRC Engineering
Date Submitted	24 July, 2026

PART A- FOUNDATIONS OF INTEGRATED GRC

1. Governance, Risk, and Compliance (GRC) are three closely connected capabilities that help an organisation achieve its objectives while managing risks and meeting its obligations.

Governance refers to the structures, roles, responsibilities, and decision-making processes that guide an organisation towards its objectives. It focuses on who makes decisions and who is accountable for them. Risk management involves identifying, assessing, and responding to events that could prevent the organisation from achieving its objectives. Compliance ensures that the organisation follows applicable laws, regulations, internal policies, contracts, and standards.

Although governance, risk, and compliance have different responsibilities, they should not operate as completely separate departments. They all support the same goal of helping the organisation achieve its objectives while managing uncertainty and meeting its obligations. Separating them can create several challenges.

One challenge is **duplication**, where different teams carry out similar risk assessments, compliance checks, or control activities without coordinating with one another. This wastes time and resources and may produce inconsistent results. Another challenge is **conflicting ownership**, where responsibilities are unclear and different teams assume someone else is responsible for managing a particular risk. This can lead to **control gaps**, where important risks are identified but no one takes responsibility for implementing or monitoring the required controls. An integrated approach allows information to be shared across teams, improving coordination, accountability, and decision-making.

For example, a commercial bank may decide to launch a mobile banking application that allows customers to transfer money, pay bills, and manage their accounts online. The objective is to improve customer convenience, increase the use of digital banking services, and remain competitive. However, the project also introduces risks such as cyberattacks, fraud, unauthorised access, service disruption, and the exposure of customers' personal or financial information.

The governance decision is whether senior management should approve the launch after confirming that the major risks have been properly assessed and appropriate controls are in place. This decision requires input from the business unit, IT, cybersecurity, risk management, and compliance teams rather than each department working independently.

The bank must also meet its compliance obligations. As a Nigerian deposit money bank, it is expected to comply with the Central Bank of Nigeria (CBN) Risk-Based Cybersecurity Framework and Guidelines for Deposit Money Banks and Payment Service Banks, as well as applicable data protection requirements when processing customers' personal information (Central Bank of

Nigeria, 2024).

This example shows why an integrated GRC approach is important. Governance provides direction and oversight, risk management helps identify and reduce threats to the bank's objectives, and compliance ensures that legal and regulatory requirements are met. Working together allows the bank to launch its mobile banking application more securely while protecting customers and reducing the risk of control failures.

2.

OCEG PHASE	Key Questions Management Should Ask	Key Artefacts	Responsible Roles
Learn	What customer data will the portal collect, store or process, and how sensitive is it? What is the business objective of the customer portal? What risks could affect the launch? Who are the customer segments and what do they expect for availability and privacy? What regulatory obligations apply (e.g., NDPA 2023)?	Business requirements and objectives; risk assessment; initial risk register entry; regulatory and compliance requirements; data-flow or data inventory; stakeholder analysis.	Business-unit management/product owner, supported by Risk and Compliance teams.
Align	Are the identified risks within the organisation's risk appetite? What controls are required? Who owns each risk and control? What security, privacy, and architecture requirements must be met before development begins? Who has the authority to approve go-live?	Risk treatment plan; control requirements; assigned risk and control owners; security, privacy, and architecture requirements; compliance checklist; project approval or governance decision; architecture sign-off; go-live approval criteria	Business Unit Manager / Project Steering Committee, with input from CISO, Risk, Compliance, and IT Governance. IT and Security leadership, including the Architecture Board, may also be involved.
Perform	Are the agreed controls being implemented and operating as designed? Is the portal secure and functioning as expected? Are employees and users adequately prepared? Is there evidence that controls are operating effectively? Are incidents detected and escalated through the agreed channels?	Implemented security and access controls; configuration records; testing results; vulnerability assessment reports; user acceptance testing; training records; compliance evidence; penetration-test results; control implementation evidence; incident logs.	IT and Security teams, with Business Unit Control Owners responsible for operational execution. IT/Development and Operations teams, supported by relevant business-unit staff.
Review	Did the portal achieve its intended business objectives, including expected uptime and security performance? Did the controls	Performance and monitoring reports; control-testing results; incident reports; audit	Business Unit Management, supported by Risk, Compliance, Internal Audit, and relevant Control Owners.

	work effectively? Were any incidents, control failures, or new risks identified? Are changes required? What did post-launch monitoring or audit reveal? What should change before the next release?	findings; updated risk register; lessons-learned report; management review records; post-launch review report; KPI/KRI dashboard; audit findings and remediation plan	Internal Audit and Business Unit Management provide their respective assurance and management roles
--	---	---	---

Feedback Loop

Learn → Align → Perform → Review → New Learn Cycle

The OCEG model is a continuous cycle rather than a one-time process. Findings from the **Review** phase should feed directly into the next **Learn** phase. For example, if a post-launch audit shows that support staff are bypassing multi-factor authentication, the organisation should reassess the associated risks and access requirements before the next release. It can then update the required controls and responsibilities during the **Align** phase, implement the improvements during the **Perform** phase, and evaluate their effectiveness during the next **Review** phase. This continuous feedback loop helps the organisation improve its controls, strengthen risk management, and reduce the chances of the same issue happening again.

3. The Three Lines Model helps an organisation clearly define who is responsible for managing risks, who provides oversight, and who provides independent assurance. In the case of a former employee whose account remained active for 45 days after leaving the organisation, the incident shows a breakdown in the access termination process. The responsibilities of each line before, during, and after the failure are outlined below.

Line	Before the Failure	During the Failure	After the Failure
First Line – Management and Operational Teams	The first line owns the day-to-day risk of inappropriate access. When an employee leaves, HR should notify the relevant teams, the business unit should begin the offboarding process, and the employee's manager together with the IT/IAM team should ensure that system access is removed promptly.	Once the failure is discovered, the first line should immediately disable the account, investigate whether it was used during the 45-day period, preserve relevant logs, and report the incident through the appropriate escalation process. The incident suggests a breakdown in first-line execution, either because the offboarding request was not raised or because IT failed to act on it.	The first line should deactivate the account, investigate the root cause, review what the account accessed during the 45-day period, and improve the offboarding process to prevent a similar incident.

Second Line – Risk, Compliance, and Oversight Functions	The second line should establish policies for user access, employee offboarding, and periodic access reviews. It should define how quickly access must be revoked, monitor compliance, and advise management on related risks.	The second line should assess the impact of the failure, determine whether it creates a regulatory or compliance issue, challenge the first line where necessary, and escalate significant risks. The incident may also indicate weaknesses in second-line monitoring because effective periodic access reviews might have identified the active account earlier.	The second line should monitor corrective actions, reassess the risk, update the risk register, and confirm that the revised controls are working as intended. It should also determine whether the incident was an isolated mistake or a wider process weakness.
Third Line – Internal Audit	Internal Audit should independently assess whether access management and employee offboarding controls are properly designed and operating effectively. It should not own or operate these controls but should periodically test them by reviewing samples of former employees to confirm that access was removed as required.	Once the issue is identified, Internal Audit may include it within its assurance activities, depending on its audit plan. It should remain independent and avoid taking responsibility for management's corrective actions.	Internal Audit should independently review whether corrective actions have been implemented and whether the revised controls are effective. It should test a sample of recent leavers to confirm that the root cause has been addressed and report its findings to the appropriate governance body or audit committee

The first line owns the risk because it carries out the day-to-day activities that create and manage it. In this case, the business unit and operational teams responsible for employee offboarding and access management are accountable for carrying out the required controls. The second line supports this by setting policies, monitoring compliance, and challenging the first line where necessary. The third line provides independent assurance by assessing whether governance, risk management, and controls are operating effectively. This reflects the Institute of Internal Auditors' Three Lines Model, which separates management's responsibility for managing risk from oversight and independent assurance.

The 45-day delay in disabling the employee's account shows that accountability was not clearly defined. The business unit may not have initiated the offboarding request, IT may not have acted on it promptly, or the monitoring process may have failed to identify the active account.

To reduce the likelihood of a similar incident, the organisation should make two improvements. First, the HR system should be integrated with the offboarding process so that an employee's departure automatically triggers account deactivation, reducing reliance on manual communication between HR, the business unit, and IT. Second, management should conduct regular access reviews with clearly assigned owners and independent oversight. Any account that remains active after an employee leaves should be treated as an exception and escalated immediately.

These improvements would strengthen accountability, improve the offboarding process, and reduce the risk of unauthorised access by former employees.

PART B - FRAMEWORK ANALYSIS AND SYNTHESIS

4.

Framework	Primary Purpose	Scope	Principal Users	Key Outputs	Business Unit Application	Strongest OCEG Phase(s)
ISO 31000	Provides principles and guidelines for managing risk and integrating risk management into organisational decision-making. It is principles-based guidance rather than a certifiable standard.	Enterprise-wide risk management across different sectors and activities and applicable to different types of risk.	Senior management, risk managers, business-unit leaders, risk owners, and decision-makers.	Risk criteria, risk assessments, risk registers, risk treatment plans, monitoring and reporting.	A business unit can identify risks affecting its objectives, assess their likelihood and impact, assign owners, and select appropriate risk treatments. The business unit can maintain a live risk register with named owners and embed risk discussions into planning.	Learn, Align, Review
COBIT 2019	Provides a framework for the governance and management of enterprise information and technology, linking IT goals to enterprise goals.	Enterprise governance and management of information and technology.	Boards, executives, CIOs, IT leaders, governance professionals, risk and audit teams.	Governance and management objectives, processes, performance measures, governance design decisions, policies, and procedures	A business unit can align technology decisions with enterprise goals, clarify accountability, and ensure that technology-related risks and resources are properly governed.	Align, Perform, Review

ISO/IEC 27001:2022	Establishes requirements for an Information Security Management System (ISMS) that manages information security risks.	Information security across people, processes, technology, and information assets within the defined ISMS scope.	Senior management, information security teams, risk managers, control owners, auditors, and compliance teams.	ISMS documentation, risk assessments, risk treatment plans, Statement of Applicability, policies, control evidence, and audit records.	A business unit can identify information assets, contribute to risk assessments, implement relevant controls, and provide evidence that controls are operating effectively.	Learn, Align, Perform, Review
NIST Cybersecurity Framework (CSF) 2.0	Helps organisations understand, assess, prioritise, and communicate how they manage cybersecurity risks through an outcome-based approach.	Cybersecurity risk management across organisations of different sizes, sectors, and maturity levels.	Cybersecurity teams, risk managers, executives, technology leaders, business-unit stakeholders, and boards.	Current and Target Profiles, cybersecurity outcomes, implementation plans, risk priorities, and improvement actions.	A business unit can compare its current cybersecurity profile with its target profile, identify gaps, prioritise improvements, and communicate cybersecurity risks and required investments to management.	Learn, Align, Perform, Review
Nigeria Data Protection Act (NDPA) 2023	Establishes a legal framework for protecting personal data and regulating its processing in Nigeria. Unlike the other instruments, it is statutory law with legal obligations.	Processing of personal data and the responsibilities of data controllers and processors within the Act's scope.	Data controllers, data processors, privacy teams, Data Protection Officers (DPOs), business units processing personal data, and the Nigeria Data Protection Commission (NDPC)	Privacy notices, records of processing activities, consent or other lawful bases, data protection impact assessments where applicable, data-subject processes, breach records, and compliance evidence.	A business unit processing personal data can identify its data flows, assess applicable obligations, review privacy notices and lawful bases, apply appropriate data protection controls, and comply with relevant regulatory requirements	Learn, Align, Perform, Review

Synthesis: Why No Single Framework Is Sufficient

No single one of these frameworks or regulations is sufficient on its own because each focuses on a different area of GRC. **ISO 31000** provides broad guidance for managing risk but does not give detailed requirements for IT governance or cybersecurity. **COBIT 2019** focuses on governing and managing enterprise information and technology but does not replace a broader risk management approach or provide detailed information security controls. **ISO/IEC 27001** provides a structured approach to information security through an ISMS, but it does not cover every area of enterprise risk or legal compliance. **NIST CSF 2.0** supports cybersecurity risk management and communication but is not a legal requirement. The **NDPA 2023**, on the other hand, is a statutory requirement for organisations within its scope and focuses specifically on data protection.

Relying on only one would therefore leave gaps. For example, ISO 31000 may support risk management without providing detailed security controls, while ISO/IEC 27001 may strengthen information security without addressing all Nigerian data protection obligations. The NDPA 2023 may address legal requirements for personal data but does not provide a complete approach to IT governance or enterprise risk management.

Using these instruments together allows an organisation to cover different areas of GRC. ISO 31000 supports risk management, COBIT 2019 supports IT governance, ISO/IEC 27001 supports information security, NIST CSF 2.0 supports cybersecurity risk management, and the NDPA 2023 addresses data protection obligations. Together, they provide a more complete approach to managing the organisation's objectives, risks, and compliance responsibilities.

- 5. A Common Control Framework (CCF) is a structured approach for managing controls that apply to multiple frameworks, standards, regulations, and contractual requirements. Instead of creating separate controls for each framework, an organisation identifies common control requirements and maps them to the different obligations they help satisfy. This reduces duplication, improves consistency, makes evidence collection more efficient, and provides clearer links between requirements, controls, and compliance obligations.

For example, an organisation may have privileged-access requirements under ISO/IEC 27001, NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-53, and COBIT 2019. Instead of creating four separate access-control processes, the organisation can establish one enterprise Privileged Access Management (PAM) control and map it to the relevant requirements of each framework. The control can then be interpreted according to the specific requirements of each framework.

Worked Example: Privileged Access Management (PAM)

CCF Element	Description
Enterprise Control	Privileged Access Management (PAM): Privileged access to critical systems and sensitive information must be restricted to authorised personnel based on business need. Privileged accounts must be approved, uniquely assigned, securely managed, regularly reviewed, and monitored. Access must be removed or modified promptly when it is no longer required.
Control Objective	To ensure that privileged access is granted only to authorised individuals for legitimate business purposes,

	appropriately protected and monitored, and removed when no longer required.
Control Owner	Chief Information Security Officer (CISO)
Evidence Item 1	Approved privileged-access request and authorisation records.
Evidence Item 2	Current privileged-account inventory showing account owners, assigned privileges, and review status.
Evidence Item 3	Periodic privileged-access review reports and/or privileged-access monitoring logs.
Control Testing Procedure 1	Select a sample of privileged accounts and inspect evidence to confirm that each account has documented business justification and appropriate management approval.
Control Testing Procedure 2	Review a sample of periodic access reviews and account changes to confirm that inappropriate or unnecessary privileged access was identified and removed or modified promptly.

Framework Mapping

Source	How the PAM Control Supports the Requirement
ISO/IEC 27001:2022	The control supports the organisation's information security risk management and access-control objectives by ensuring that privileged access is authorised, restricted, reviewed, and managed within the ISMS.
NIST CSF 2.0	The control contributes to cybersecurity outcomes relating to protecting systems and data through identity and access management. It can support the CSF's broader approach to managing cybersecurity risk by reducing the likelihood of unauthorised access.
NIST SP 800-53	The PAM control can be mapped to specific access-control and account-management controls, including controls addressing least privilege, privileged accounts, account management, and access enforcement.
COBIT 2019	The control supports the governance and management of information and technology by establishing accountability and ensuring that access to technology resources is appropriately managed and monitored.

How One Control Satisfies Multiple Obligations

A CCF allows one well-designed control to address multiple obligations because the underlying risk may be the same even when different frameworks describe it differently. In this example, the common risk is unauthorised or excessive privileged access. The organisation can therefore use one PAM control, with a defined owner, evidence, and testing process, rather than creating a separate operational process for every framework.

However, using a common control does not mean that all frameworks can be treated in exactly the same way. Each has its own purpose, scope, terminology, and requirements. ISO/IEC 27001 focuses on information security management through an ISMS, NIST CSF 2.0 provides an outcome-based approach to cybersecurity risk, NIST SP 800-53 provides detailed security and privacy controls, and COBIT 2019 focuses on the governance and management of enterprise information and technology. The PAM control must therefore be mapped and tested against the specific requirements of each applicable framework.

This approach improves traceability and accountability because the organisation can show which control addresses each obligation, who owns it, what evidence demonstrates that it is operating, and how its effectiveness is tested. It also reduces duplication by avoiding multiple overlapping controls and evidence requests for the same underlying risk.

6. The statement that “policy is written at the centre, but risk is taken and controls are performed at the edge” highlights an important reality about how Governance, Risk, and Compliance (GRC) works in an organisation. Senior management and central GRC functions may develop policies, frameworks, and guidelines, but business units are where employees make decisions, interact with customers, use information systems, and carry out daily activities. Therefore, the success of GRC depends on whether business-unit employees understand and consistently apply the requirements established by the organisation.

One important factor is organisational culture and incentives. Employees often experience governance through the behaviour of their managers and what the organisation rewards. For example, if employees are rewarded only for meeting sales or operational targets, they may be tempted to ignore customer verification procedures or bypass controls to achieve their targets more quickly. A strong GRC culture should encourage employees to follow procedures, report problems, challenge unsafe decisions, and escalate risks. Management should also recognise responsible risk behaviour, such as reporting a near-miss, instead of creating a culture where employees hide problems because they are afraid of being blamed. This shows that GRC is not only about having policies at the centre but also about how those policies are reflected in the decisions and behaviour of business-unit management.

Risk registers, control ownership, and escalation are also important at the business-unit level. A risk register should identify significant risks, their likelihood and impact, existing controls, risk owners, treatment actions, and target dates. However, maintaining a risk register is not enough. Each significant risk and key control should have a named owner who is responsible for monitoring it and providing evidence that the control is operating effectively. This reduces the chance of everyone assuming that someone else is responsible. Business units should also have clear escalation procedures so that serious risks and control failures are reported to the appropriate level of management. For example, if a business unit discovers a serious cybersecurity vulnerability, it should not simply record the issue and continue normal operations. The issue should be escalated according to the organisation's risk appetite and incident-management procedures.

Evidence and management review help complete the GRC cycle. Evidence such as access review records, approval logs, training records, vulnerability assessment reports, incident reports, and management sign-offs demonstrates that controls are actually being performed and not simply documented. Business-unit management should regularly review risk registers, control performance, incidents, audit findings, and compliance issues. This connects with the OCEG Learn, Align, Perform, and Review cycle because findings from the Review phase should inform the next Learn cycle and support continuous improvement.

Five Practical Actions for a Business-Unit Leader in the Next 90 Days

1. **Review the business unit's top risks:** Review the risk register and confirm that significant risks are current, properly assessed, and linked to the unit's objectives.
2. **Assign clear ownership:** Ensure that every significant risk and key control has a named owner with clearly defined responsibilities.
3. **Test key controls and collect evidence:** Identify important controls and confirm that they are operating effectively. Ensure that reliable evidence is retained.
4. **Strengthen escalation and reporting:** Establish clear procedures for escalating significant risks, control failures, incidents, and compliance issues.
5. **Conduct a formal management review:** At the end of the 90-day period, review risk trends, control performance, incidents, audit findings, and outstanding actions. Use the results to update the risk register and control improvement plan.

In conclusion, effective GRC is not achieved simply by creating policies at the organisational centre. It succeeds when those policies are understood and translated into practical action where business activities take place. Business-unit management must create accountability, encourage responsible risk behaviour, monitor controls, maintain evidence, and ensure that important issues are escalated and reviewed. When the “edge” of the organisation is connected to the “centre,” GRC becomes a continuous management capability that supports business objectives and organisational resilience.

References

Central Bank of Nigeria. (2024). *Risk-based cybersecurity framework and guidelines for deposit money banks and payment service banks*.

Federal Republic of Nigeria. (2023). *Nigeria Data Protection Act, 2023*.

International Cybersecurity and Digital Forensics Academy. (2026). *Week 2: GRC Engineering – Governance, Risk, and Compliance: An Integrated Capability Course lecture slides*.

Institute of Internal Auditors. (2020). *The IIA's Three Lines Model: An update of the Three Lines of Defense*.

International Organization for Standardization. (2018). *ISO 31000:2018: Risk management — Guidelines*.

International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.

ISACA. (2018). *COBIT 2019 framework: Governance and management objectives*.

National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5). U.S. Department of Commerce.

Open Compliance and Ethics Group. (n.d.). What is GRC (Governance, Risk, and Compliance)?

Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Paper CSWP 29). National Institute of Standards and Technology.